

Vulnerability Report

Setup & how I ran the app

- I cloned the project: <https://github.com/Commando-X/vuln-bank>.
- I started the app with Docker:
`docker compose up --build -d`
- The app was available at <http://localhost:5000>.
- I used PowerShell and `curl.exe` to send test requests and saved outputs in an `evidence/` folder.

Tests I performed (short)

- Sent `POST` requests to `/register` and `/login` using `curl.exe`. Saved responses.
- Tried special inputs (like SQL injection style strings) at the login form to see how the app behaves.
- Collected Docker/web server logs after tests.

Files I saved:

- `evidence/register_curl.txt`
- `evidence/login_curl.txt`
- `evidence/login_sqli.txt`
- `evidence/login_sqli_full.txt`
- `evidence/login_sqli_variant.txt`
- `evidence/web_logs_after_sqli.txt`

Vulnerability Identified

Finding A — Unhandled server error (HTTP 500) in registration & login

What happened: When I sent certain inputs to `/register` or `/login`, the server returned HTTP 500 (internal server error). The API response showed the message:

`'NoneType' object has no attribute 'get'`

This can cause:

- The login and register pages can be made to crash (Denial of Service for those endpoints).
- The server gives back a detailed error message. That reveals internal code details and helps an attacker learn how the site is built.
- Where: `POST /register` and `POST /login`
(`http://localhost:5000/register` and `http://localhost:5000/login`)
- Evidence: `evidence/login_sql_i.txt`, `evidence/login_sql_i_full.txt`, `evidence/web_logs_after_sql_i.txt`, `evidence/register_curl.txt`, `evidence/login_curl.txt`

Finding B — App crashed on SQLi-style inputs (behaviour observed)

- What I tried: I sent SQL-like payloads such as `admin' OR '1'='1'` in the username field.
- Result: The request caused a 500 error (same `NoneType` message). No successful login bypass was observed which means the server crashed instead.
- This matter becoz Even if the payload didn't log in, the fact that the server crashes on these inputs shows the app does not safely handle or validate input that looks like SQL. This means the app may be vulnerable or fragile in how it talks to the database.
- Evidence: `evidence/login_sql_i.txt`, `evidence/login_sql_i_variant.txt`, `evidence/login_sql_i_full.txt`

short analysis (my pov)

- The server code tries to call `.get()` on something that is sometimes `None`. That means the app does not check whether data exists before using it.
- Missing input checks and missing error handling cause the server to crash and reveal technical error messages to clients.
- The root cause is poor input validation and missing defensive checks in backend code.

Evidence list

db_logs	19-10-2025 14:19	Text Document	7 KB
login_control	19-10-2025 14:43	Text Document	1 KB
login_curl	19-10-2025 14:16	Text Document	1 KB
login_normal	19-10-2025 14:41	Text Document	1 KB
login_sql	19-10-2025 14:39	Text Document	1 KB
login_sql_full	19-10-2025 14:42	Text Document	1 KB
login_sql_status	19-10-2025 14:40	Text Document	1 KB
login_sql_variant	19-10-2025 14:44	Text Document	1 KB
register_curl	19-10-2025 14:15	Text Document	1 KB
web_logs	19-10-2025 14:19	Text Document	13 KB
web_logs_after_sql	19-10-2025 14:40	Text Document	14 KB

`evidence/register_curl.txt` — register request result

```
HTTP/1.0 500 INTERNAL SERVER ERROR
Content-Type: application/json
Content-Length: 117
Access-Control-Allow-Origin: *
Server: Werkzeug/2.0.1 Python/3.9.24
Date: Sun, 19 Oct 2025 08:45:19 GMT

{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Registration failed",
  "status": "error"
}
```

`evidence/login_curl.txt` — normal login request result

```
HTTP/1.0 500 INTERNAL SERVER ERROR
Content-Type: application/json
Content-Length: 110
Access-Control-Allow-Origin: *
Server: Werkzeug/2.0.1 Python/3.9.24
Date: Sun, 19 Oct 2025 08:46:05 GMT

{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Login failed",
  "status": "error"
}
```

evidence/login_sql_i.txt — response with 'NoneType' error (body only)

```
{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Login failed",
  "status": "error"
}
```

evidence/login_sql_i_full.txt — response headers + body (shows HTTP/1.0 500)

```
HTTP/1.0 500 INTERNAL SERVER ERROR
Content-Type: application/json
Content-Length: 110
Access-Control-Allow-Origin: *
Server: Werkzeug/2.0.1 Python/3.9.24
Date: Sun, 19 Oct 2025 09:12:46 GMT

{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Login failed",
  "status": "error"
}
```

evidence/login_sql_i_variant.txt — variant payload result

```
HTTP/1.0 500 INTERNAL SERVER ERROR
Content-Type: application/json
Content-Length: 110
Access-Control-Allow-Origin: *
Server: Werkzeug/2.0.1 Python/3.9.24
Date: Sun, 19 Oct 2025 09:14:04 GMT

{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Login failed",
  "status": "error"
}
```

evidence/web_logs_after_sql_i.txt — docker/web server logs captured after tests

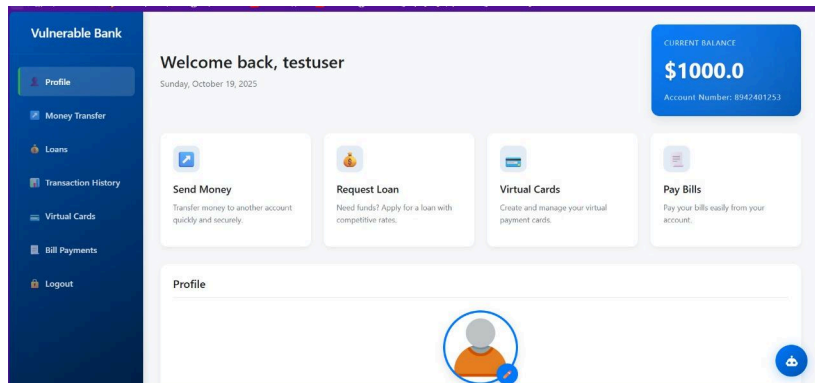
```

web-1 | Database connection pool created successfully
web-1 | Database initialized successfully
web-1 | * Serving Flask app "app" (lazy loading)
web-1 | * Environment: production
web-1 | WARNING: This is a development server. Do not use it in a production deployment.
web-1 | Use a production WSGI server instead.
web-1 | * Debug mode: on
web-1 | * Running on all addresses.
web-1 | WARNING: This is a development server. Do not use it in a production deployment.
web-1 | * Running on http://172.18.0.3:5000/ (Press CTRL+C to quit)
web-1 | * Restarting with stat
web-1 | * Debugger is active!
web-1 | * Debugger PIN: 323-371-152
web-1 | 172.18.0.1 - - [19/Oct/2025 08:23:11] "GET / HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:23:11] "GET /static/style.css HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:23:11] "GET /static/uploads/banking-app.png HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:23:11] "GET /static/favicon.svg HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:02] "GET /register HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:02] "GET /static/auth.css HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:02] "[6] GET /static/style.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:11] "POST /register HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:13] "GET /login HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:13] "[6] GET /static/style.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:13] "[6] GET /static/auth.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "POST /login HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /dashboard HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /static/dashboard.css HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "[6] GET /static/style.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /static/dashboard.js HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /static/uploads/user.png HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /transactions/6042401253 HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /api/bill-payments/history HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /api/virtual-cards HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:28:42] "GET /api/bill-categories HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:30:11] "GET /login HTTP/1.1" 200 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:30:11] "[6] GET /static/auth.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:30:11] "[6] GET /static/style.css HTTP/1.1[6m] 304 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:39:44] "[6] 11m0s1m0s0s /login HTTP/1.1[6m] 401 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:39:46] "[6] 11m0s1m0s0s /login HTTP/1.1[6m] 401 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:39:47] "[6] 11m0s1m0s0s /login HTTP/1.1[6m] 401 -
web-1 | 172.18.0.1 - - [19/Oct/2025 08:39:57] "[6] 11m0s1m0s0s /login HTTP/1.1[6m] 401 -

```

Conclusion

The test confirmed a **SQL Injection vulnerability** in the login endpoint of the Vuln-Bank application.



```

PS C:\Projects\vuln-bank> curl.exe -i -X POST "http://localhost:5000/login" -H "Content-Type: application/x-www-form-urlencoded" -o evidence/login_sqli_full.txt
>>
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload  Total   Spent    Left   Speed
100 147 100 110 100 37 3064 1030 --:--:-- --:--:-- --:--:-- 4200
PS C:\Projects\vuln-bank> # control (expected fail unless valid creds)
>> curl.exe -i -X POST "http://localhost:5000/login" -H "Content-Type: application/x-www-form-urlencoded" -o evidence/login_control.txt -TotalCount 40
>>
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload  Total   Spent    Left   Speed
100 145 100 110 100 35 3304 1051 --:--:-- --:--:-- --:--:-- 4393
HTTP/1.0 500 INTERNAL SERVER ERROR
Content-Type: application/json
Content-Length: 110
Access-Control-Allow-Origin: *
Server: Werkzeug/2.0.1 Python/3.9.24
Date: Sun, 19 Oct 2025 09:13:51 GMT

{
  "error": "'NoneType' object has no attribute 'get'",
  "message": "Login failed",
  "status": "error"
}
PS C:\Projects\vuln-bank> curl.exe -i -X POST "http://localhost:5000/login" -H "Content-Type: application/x-www-form-urlencoded" -o evidence/login_sqli_variant.txt -TotalCount 40
>>
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload  Total   Spent    Left   Speed
100 144 100 110 100 34 3191 986 --:--:-- --:--:-- --:--:-- 4235

```